

INSTITUTO INFNET
ESCOLA SUPERIOR DE TECNOLOGIA
GRADUAÇÃO EM ENGENHARIA DE
SOFTWARE



Turma - GRLENGR2C1-N2-L1
Curso - Desenvolvimento Seguro de
Aplicações Web
Professor - Fabiano Domingues

AT

Alunos: Ademir de Lucca Junior.

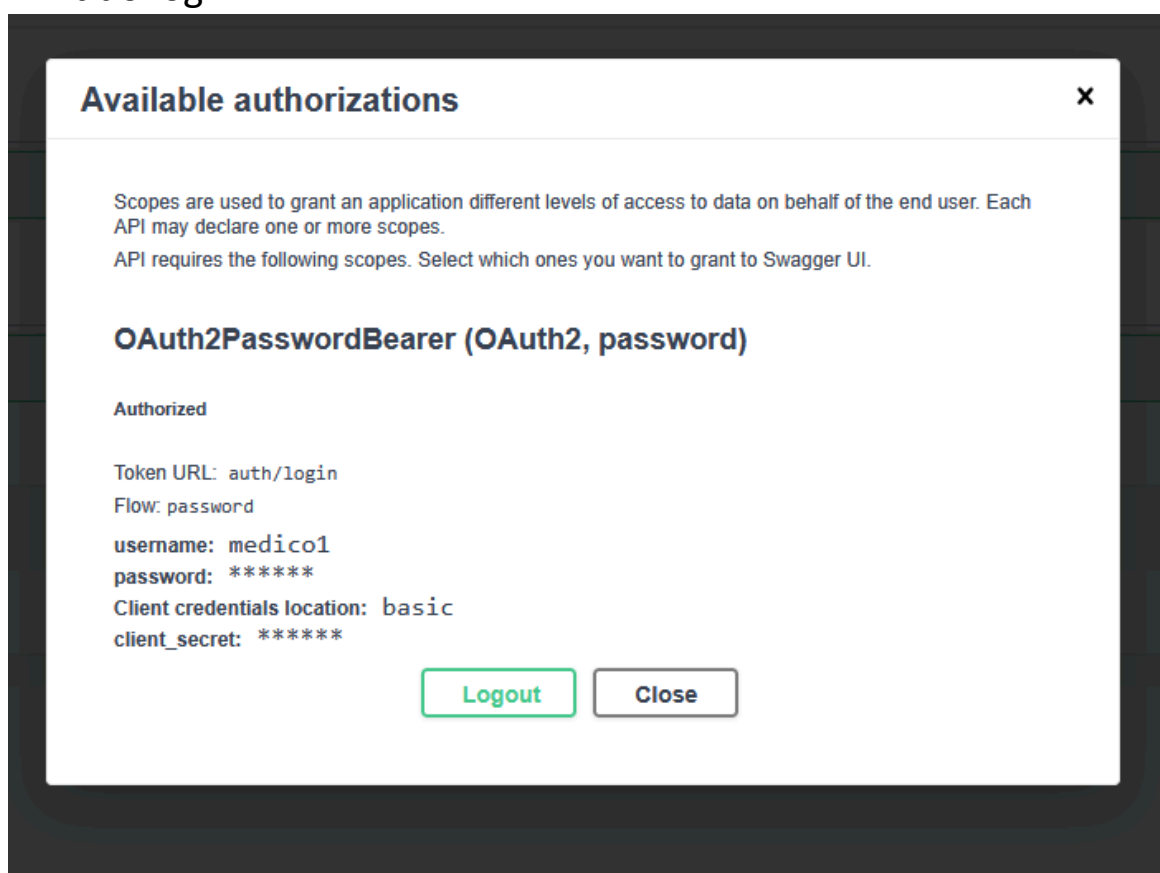
3 de out. de 2026

Exercícios

Github:

<https://github.com/yADMh/Desenvolvimento-Seguro-de-Aplicacao-Web>

Print do login



print da tela de login para colocar os campos

Available authorizations x

medico1|

password:

...

Client credentials location:

Authorization header ▾

client_id:

client_secret:

Scopes: [select all](#) [select none](#)

☒ *read:consultas*
Ler consultas

☒ *write:consultas*
Criar consultas

☐ *role:admin*
Privilegios administrativos

Authorize

Close

post consulta funcionando

Consultas

POST

/consultas/

Criar Consulta

Parameters

No parameters

Request body required

application/json

Edit Value | Schema

{
 "paciente_id": 1,
 "profissional_id": 1,
 "data_horario": "2026-09-21T23:34:16.024Z",
 "especialidade": "string"
}

Execute

Clear

Responses

Curl

curl -X 'POST' \
 'http://127.0.0.1:8000/consultas/' \
 -H 'accept: */*' \
 -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpvcC9.eyJzdMkiOiJlOTYtZW@py29fdGVzdgUjLCJyZXNpdGUiOiJlY29uc3VsdfzOnJlWQjLCJjb25rdmVzdgUjLCJpdGUjXSuibmZhX3ZlcmluaWwIjp8cnVlLCJleHAiOjE3OTAwMzuzHjR9.G0
 -H 'Content-Type: application/json' \
 -d '{
 "paciente_id": 1,
 "profissional_id": 1,
 "data_horario": "2026-09-21T23:34:16.024Z",
 "especialidade": "string"
 }'

Request URL

http://127.0.0.1:8000/consultas/

Server response

Code

Details

200

Request body

{
 "id": 50,
 "paciente_id": 1,
 "profissional_id": 1,
 "data_horario": "2026-09-21T23:34:16.024000",
 "especialidade": "string",
 "status": "agendada"
}

Download

get consulta funcionando

GET

/consultas/{consulta_id}

Obter Consulta

Parameters

Cancel

Name	Description
consulta_id * required	
integer	
(path)	

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
  'http://127.0.0.1:8000/consultas/1' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVC99.eyJ1bm90cmVudCI6IiJ1bm90cmVudC99.eyJ1bm90cmVudCI6IiJ1bm90cmVudC99'
```

Request URL

```
http://127.0.0.1:8000/consultas/1
```

Server response

Code	Details
200	Response body <pre>{ "id": 1, "paciente_id": 99, "profissional_id": 1, "data_horario": "2026-09-20T11:22:41.105456", "especialidade": "Cardiologia", "status": "agendada" }</pre> Download Response headers <pre>content-length: 139 content-security-policy: default-src 'self'; script-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; img-src 'self' data; content-type: application/json date: Mon, 21 Sep 2026 23:36:13 GMT server: uvicorn strict-transport-security: max-age=31536000; includeSubDomains x-content-type-options: nosniff x-frame-options: DENY</pre>

Responses

Code	Description	Links
200	Successful Response	No links

Media type

application/json

Controls Accept header.

5

MFA simulado

client_secret

string

client_secret

☒ Send empty value

username

string

admin

☐ Send empty value

password

string

123

☐ Send empty value

scope

string

scope

☒ Send empty value

Execute

Clear

Responses

Curl

```
curl -X 'POST' \
  'http://localhost:8080/auth/login' \
  -H 'accept: application/json' \
  -H 'Content-Type: application/x-www-form-urlencoded' \
  -d 'grant_type=password&client_id=&client_secret=admin&password=123&scope='
```

Request URL

http://localhost:8080/auth/login

Server response

Code	Details
401	Error: Unauthorized

401

undocumented

Response body

```
{
  "detail": "MFA required"
}
```

Response headers

```
access-control-allow-credentials: true
content-length: 25
content-type: application/json
date: Sat, 03 Oct 2026 20:20:34 GMT
server: uvicorn
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-frame-options: DENY
```

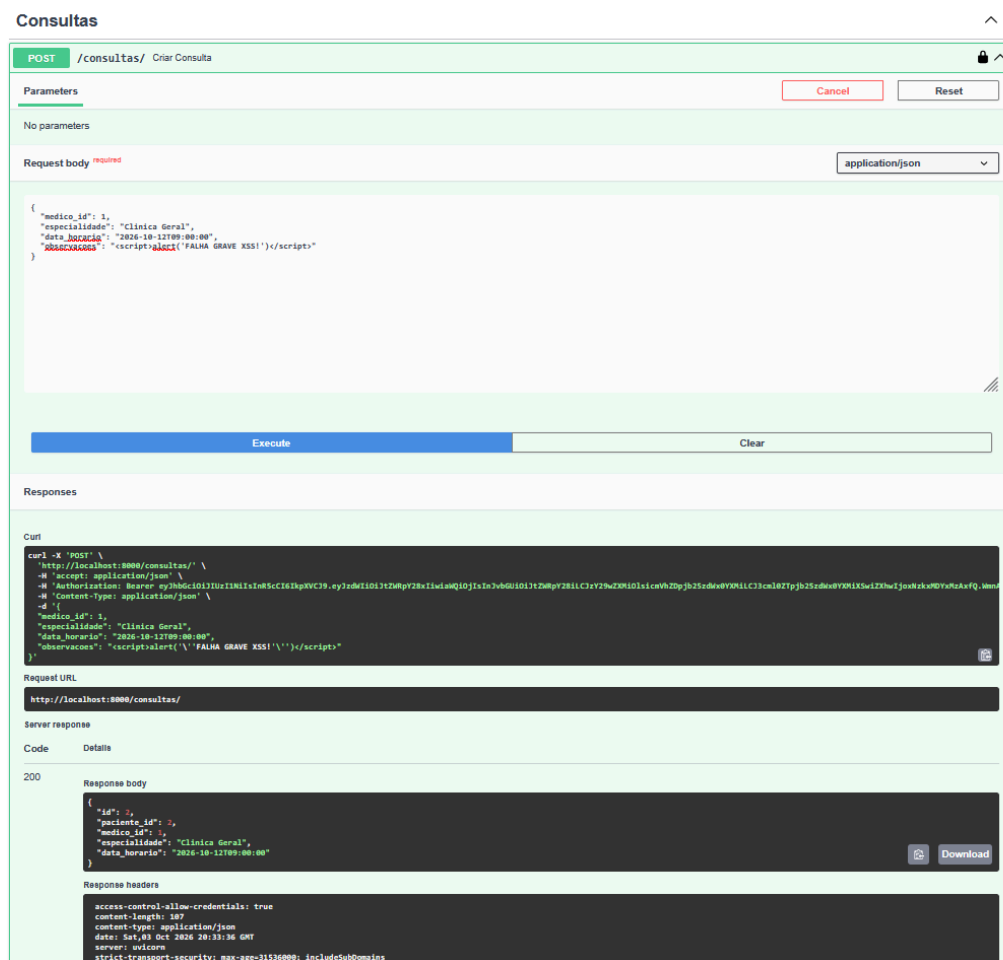
Responses

Code	Description	Link
------	-------------	------

ERRO 422

[illegible]

XSS Jinja2



Sistema de Agendamento da Recepção

Consultas

- Data: 2026-10-03 20:29:43.020000 - Especialidade: Cardiologia - Obs: string
- Data: 2026-10-12 09:00:00 - Especialidade: Clínica Geral - Obs: <script>alert("FALHA GRAVE XSS!")</script>

get consultado com erro(BOLA)

GET

/consultas/{consulta_id} Ler Consulta

Parameters

Cancel

Name	Description
consulta_id required integer (path)	1

Execute

Clear

Responses

Curl

```
curl -X 'GET' \
  'http://localhost:8080/consultas/1' \
  -H 'accept: application/json' \
  -H 'Authorization: bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWI0Ij09bmVpZm90ZTEiCjZCI6Mywicw9zTS16InBhY2llbm81Iiwic2NvcGZiIjpbInJlYWQyY29uc3VsdGZlIiwiaW40cCI6MTc5MTA2MTgzQW0. qYyubgm5fyG0S2z78y' \
  http://localhost:8080/consultas/1
```

Request URL

http://localhost:8080/consultas/1

Server response

Code	Details
403	Error: Forbidden

Undocumented

Response body

```
{
  "detail": "Acesso a prontuario de terceiros bloqueado"
}
```

Download

Response headers

```
content-length: 55
content-type: application/json
date: Sat, 03 Oct 2026 20:40:45 GMT
server: uvicorn
strict-transport-security: max-age=31536000; includeSubDomains
x-content-type-options: nosniff
x-frame-options: DENY
```

Responses

Code	Description	Links
200	Successful Response	No links

Media type

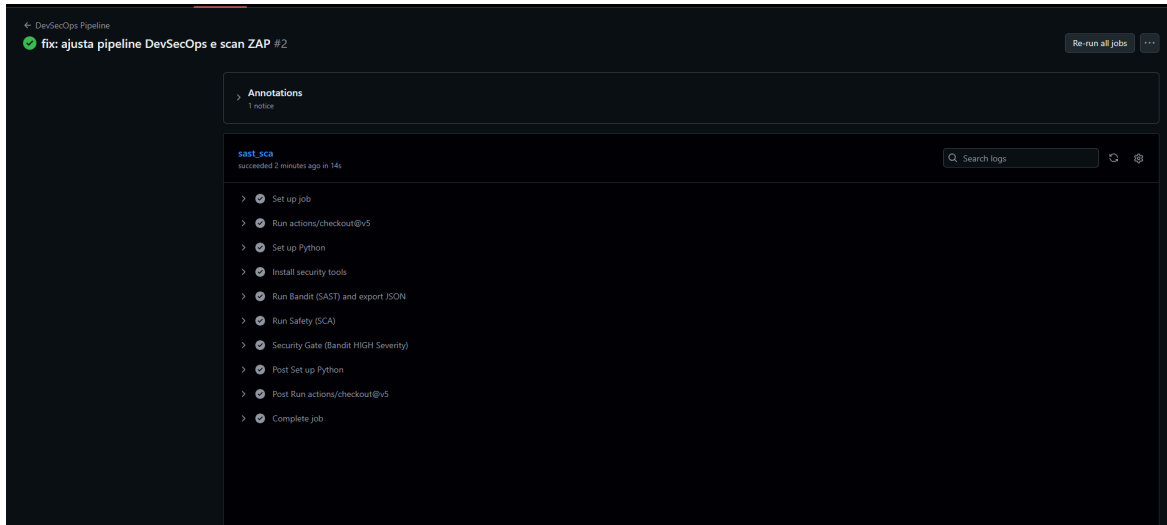
application/json

Controls Accept header.

Example Value

Schema

SAST e SCA Github



DAST e Zap Github

